

Trust: Primary First

Date: 21/02/23

Report: Trustee **DPE consultant: Stuart Lee/Tammy Buchanan**
Trust Staff: Kerry Riley and Clark Taylor

Report details

A 2 day onsite visit took place on the 21st and 22nd February 2023. This was arranged to complete a physical audit of 5 of the Trust schools. In addition to the 5 schools being visited, an information security meeting was arranged with the Trusts IT manager Clark Taylor (CT) and Kerry Riley (KR). Tammy Buchanan (TB) DPEs IT specialist was also present for the information security meeting.

Schools visited during the 2 days were:

- Barnehurst Federation of Schools
- Lessness Heath Primary
- Mayplace Primary
- Westcourt Primary
- Springhead Park Primary

The purpose of a physical audit of the schools is to determine risks to physical data handling, storing and processing practices, and make recommendations where required. Time was also spent with each head teacher to talk through best practice and answer any data protection queries/issues the schools may have had.

The information security meeting explored the main Information security risks in the sector and best practice for the Cloud, network and devices. The meeting allowed for IT specialist introductions and planning for future meetings. A recent SAR relating to iPads was also discussed.

The report is broken down into the following sections:

1. School audit feedback
 2. Information security and recommendations
 3. Trust next steps
 4. Useful reference documents
- Appendix 1 - summarising walk findings

1. School audit visit feedback

Each school visited exhibited good data protection practices and it was rewarding as a consultant to observe how the Trust and schools had already advanced in their use of Cloud based solutions for processing, sharing and storing school data securely. For example: CPOMS for Safeguarding and Microsoft 365 for sharing information online; instead of having physical data and folders. Each school had CCTV with secure access to the school and offices/areas where sensitive data is processed. Visitor checks were in place.

Head teachers at each school had been proactive prior to the visits in ensuring best practice was being followed. DPE uses a Making the Rounds app when completing walks and walk findings for each school have been populated in the app for each school. **Observations and recommendations from the walk have been summarised within appendix 1.** Not all recommendations made are relevant to all schools. For best practice it is still worth communicating the summarised findings to all schools to check against, so that everyone is aware. The DPE quick reference best practice poster was also disseminated prior to the visits that can be used to compare against.

One school used their caretaker to feed back from end of day caretaker routines any issues with unlocked laptops and/or data that may have been left out. This is then fed back to staff. This practice might be something that can be exploited across the Trust and possibly form part of CPD for members of the premises team.

2. Information and cyber security meeting

A recent subject access request and use of iPads coincided with the information security meeting and enabled discussion to take place on best practice and mitigating risks. The Trust is the data controller so is ultimately responsible for equipment, including any leased equipment. Under the UK GDPR the Trust is responsible for ensuring adequate technical and organisational measures are in place, including how these devices are used. CT was aware of Trust wide information security risks and has been identifying and putting mitigations in place. CT has been in the role for less than a year, so is still familiarising himself with systems and IT suppliers, including how these operate for the Trust.

Recommendations - whole Trust:

It was agreed that TB (DPE) would work with the Trust to support the completion of the cyber security checklist to identify additional cyber/information security risks.

SL will work with KR and the Trust to complete the ICO accountability tracker.

Both the above will support in identifying any gaps in the privacy programme and remedial actions required.

Recommendations in relation to the SAR:

Document how iPads are used i.e. instant messaging and data storage (what is stored on iPads).

Review of whether pupil school reports are stored on the iPads as a way of sharing with parents (DPE may have been incorrectly advised about this during a previous meeting). A more appropriate way to share reports would be via a parent communication system or app already used that is linked to the parent and pupil and uses cloud storage.

Ensure appropriate controls are in place for iPads and mobile devices and that these are linked to school accounts.

Ensure appropriate filtering is in place for any devices taken home and that there are restrictions for downloads; enabling appropriate cyber security measures when brought back into school and linked to the school network.

Check the current contract held with parents as the iPad lease is in the Trust's name and these are Trust devices, with the Trust being the data controller.

Controlling app downloads and types of apps as a cyber security measure to reduce risk to the school network.

Review of acceptable use policy for iPads that go home.

Phasing out the use of iMessaging and moving to teams (Wayfield) to be completed as soon as possible.

Confirm there is no use of iCloud other than for Apple accounts linked to the iPads for Apple Classroom.

Look at the use of Live Events rather than Teams meetings for certain meetings as the issue of some third party emails were viewed in Teams meetings.

Review email retention for both the Deleted and Sent folders.

Note: this was not an IT security audit and recommendations only include information obtained from the recent SAR and meeting that took place. In addition, please refer to the Appendix for comments on laptops and interactive screens.

3. Trust next steps

- Action audit walk findings
- Information security meeting(s) as required with TB and CT to complete the cyber/information security checklist
- Completion of the ICO accountability tracker to support a gap analysis
- Data retention for electronic files (Primary specific to be considered), including MIS, emails and developing appropriate procedures and processes across the Trust
- Record of processing and DPIAs (including changing IT providers)

4. Useful reference documents:

- [Quick reference sheet](#)
- [Information and cyber security best practice area](#)
- [Records management best practice area](#)
- [Physical security policy](#)
- [DPE consent guidance](#)

Appendix 1

Audit walk observations and recommendations

As the Trust is utilising Cloud solutions there was minimal physical data on displays and good practice was observed in general.

Classrooms

Nursery/reception area(s): Birthday displays with photo, forename and part of the child's DoB.

Allergy list on display.

Recommendations: Review area and where photo, forename and part of the DoB is showing reduce the amount of information on display.

Add allergy lists to folders and add to storage when not in use.

Classroom laptops/desktops: Laptops and desktops observed with applications open and no staff in the work area.

Recommendations: Reminder to staff to use Windows key + L to lock laptops and desktops when not in their work area. Same rule applies even if there is an auto lock function enabled.

Classroom interactive boards: Interactive screens could be accessed when it appeared laptops were locked.

Recommendations: SL discussed with the Trusts IT who will investigate how these can be securely locked.

Classroom fire lists: Firelists are required when students have to be evacuated and full name is used in the majority of cases.

Recommendation: Add a cover sheet and heading to the firelist sheet/clipboards.

Coat pegs and corridors: Some coatpegs had a photo and forename in corridors.

Recommendations: Where there is a teaching and learning justification (learning names) and the area is a controlled space this is acceptable and should be assessed by school and area. In addition, review consent and schools could consider minimising data for example, using a caricature or picture with the forename rather than a photo.

CCTV signage: Lack of signage notifying of CCTV cameras.

Recommendations: Add signage where cameras are located that do not have clear signage or no signage displayed.

CCTV access logs: There are digital footprints that can be used for access logs although there are no records to record reasons why CCTV was accessed.

Recommendations: Investigate whether the CCTV systems allow for entering of text to keep a record. If not, download and use DPEs access logs for staff responsible for CCTV to use.

Visitor sign in: Electronic systems of sign-in were used although not all had visitor statements.

Recommendations: Add the following statement to the electronic sign in systems: Visitor information is collected for health and safety, record of official visits and safeguarding. The general/visitors privacy notice is available on the Trust website, or you can ask at reception for a paper copy.

Reception area PC monitors: Schools had predominantly open plan working areas with reception staff monitors easily viewed.

Recommendation: Where monitors could be viewed by students and visitors add privacy screens to monitors - if not already in place.

Offices, including SEND and LT offices: Good practice observed in general with all areas secure. Some information was observed on open display with no staff in the work area.

Recommendations: General reminders required:

- Avoid having large amounts of data out when not in the work area.
- Avoid sensitive documents/files being left on open display by storing securely when not in the work area.
- Remind staff to check physical folders and complete a data cleanse to ensure information is up to date and no documents/files remain of leavers and/or contain outdated information.

Kitchen folders with allergy information: Folder systems used for sharing allergy/medical information. Some schools used lanyards to identify food choices.

Recommendations:

- Check the process for ensuring folders are up to date and leavers are removed from folders.
- Can some sensitive information be minimised without impacting the safety of pupils?
- Where possible, add folders with sensitive information to the kitchen offices at the end of the school day (kitchens are locked at night).